System Risk Assessment — CI/CD and Artifact Platform

Larkspur Logistics, Inc. · System Risk Assessment · SRA-2026-02 v1.4

Field	Value
Document id	SRA-2026-02
Version	1.4
Classification	INTERNAL — CONFIDENTIAL
System	CI/CD and Artifact Platform
Owner team	Platform Engineering
Assessment date	2026-05-22
Next review	2026-11-22
Assessor	Security Operations (SecOps), with Platform Engineering
Exposure	internal
Data classification	Confidential

1. Purpose and scope

This assessment documents the source control, build, artifact and deployment tooling that every engineering team at Larkspur depends on. Because the platform holds source code, build secrets and the signing material for container images, and because it has credentials to deploy into production clusters, a compromise of this system is a compromise of everything built on it. The assessment records what the platform runs and how it is reached so that SecOps can judge new vulnerabilities quickly.

2. System overview

The platform consists of a self-managed GitLab Enterprise Edition instance for source control, merge requests and CI pipelines; a Jenkins controller kept for the legacy warehouse-management build jobs that have not been migrated to GitLab CI; a JFrog Artifactory pair as the artifact repository and proxy for external package registries; a Harbor registry for container images; and a Kubernetes cluster that runs the GitLab runners, Argo CD and the shared build services. About 310 engineers and 60 service accounts use the platform; it executes around 4,000 pipeline jobs per day.

Data classification is Confidential: the platform holds all application source code, CI variables (some of them credentials for downstream systems), image signing keys and the deployment credentials Argo CD uses for the production clusters. It does not process customer data. Availability tier is Tier 2 (business hours, eight-hour recovery objective); an outage stops releases but not operations.

Staff authenticate through the corporate Keycloak staff realm with MFA. Three Jenkins service accounts still use local credentials (finding F-2026-021). Platform Engineering administers the hosts through the management bastion.

3. Architecture and hosts

All components sit on the internal engineering segment and are reachable only from the engineering VPN and the office networks; there is no internet ingress. Outbound access to public package registries (PyPI, npm, Maven Central, Docker Hub) goes through Artifactory's remote repositories via the egress proxy, so

build hosts themselves have no direct internet route. GitLab runners and Jenkins agents run as pods in the platform Kubernetes cluster; Jenkins agents connect inbound to the controller over the JNLP (Remoting) port.

Argo CD in the same cluster watches the deployment repositories in GitLab and applies manifests to the production and staging clusters using cluster-scoped credentials stored as Argo CD cluster secrets. Harbor stores the images produced by the pipelines and is the only registry the production clusters are allowed to pull from.

3.1 Host inventory

Hostname	IP address	Zone	Role	Operating system
gitlab-01.corp.example	198.51.100.60	Internal (engineering)	GitLab EE application and bundled PostgreSQL	Ubuntu 24.04 LTS
gitlab-gitaly-01.corp.example	198.51.100.65	Internal (engineering)	Gitaly repository storage	Ubuntu 24.04 LTS
jenkins-01.corp.example	198.51.100.70	Internal (engineering)	Jenkins LTS controller	RHEL 9.5
artifactory-01.corp.example	198.51.100.75	Internal (engineering)	JFrog Artifactory (primary)	RHEL 9.5
artifactory-02.corp.example	198.51.100.76	Internal (engineering)	JFrog Artifactory (secondary)	RHEL 9.5
harbor-01.corp.example	198.51.100.85	Internal (engineering)	Harbor container registry	Ubuntu 24.04 LTS
k8s-plat-cp-01.corp.example	198.51.100.80	Internal (engineering)	Kubernetes control plane	Ubuntu 24.04 LTS
k8s-plat-cp-02.corp.example	198.51.100.81	Internal (engineering)	Kubernetes control plane	Ubuntu 24.04 LTS
k8s-plat-cp-03.corp.example	198.51.100.82	Internal (engineering)	Kubernetes control plane	Ubuntu 24.04 LTS
k8s-plat-w-01..06.corp.example	198.51.100.90-95	Internal (engineering)	Kubernetes workers (runners	Ubuntu 24.04 LTS
bastion-01.mgmt.corp.example	192.0.2.5	Management	SSH bastion (MFA)	Ubuntu 24.04 LTS

4. Software bill of materials

The components below were confirmed from package manifests and running processes during the assessment. Versions are as deployed on the assessment date.

Component	Vendor / project	Version	Role in the system	Deployed on
GitLab Enterprise Edition	GitLab Inc.	19.2.4	Source control, merge requests, CI/CD pipelines	gitlab-01, gitlab-gitaly-01
JFrog Artifactory	JFrog	7.111.12	Artifact repository and remote proxy for public registries	artifactory-01, artifactory-02
Jenkins	Jenkins project	2.568.1	Legacy build controller for the warehouse-management jobs	jenkins-01
Jenkins Script Security Plugin	Jenkins project	1402.v94c9ce464861	Sandbox for Groovy pipeline scripts on the Jenkins controller	jenkins-01
Argo CD	Argo project (CNCF)	3.3.12	GitOps deployment to the staging and production clusters	platform Kubernetes cluster (namespace argocd)

Component	Vendor / project	Version	Role in the system	Deployed on
Harbor	Harbor project (CNCF)	2.15.1	Container image registry with vulnerability scanning	harbor-01
Kubernetes	Kubernetes project (CNCF)	1.33.2	Platform cluster for runners, agents, Argo CD and shared services	k8s-plat-cp-01..03, k8s-plat-w-01..06
Docker Engine	Docker Inc.	28.1.1	Image builds on the dedicated build nodes	k8s-plat-w-05, k8s-plat-w-06

4.1 Component notes

GitLab Enterprise Edition 19.2.4

GitLab EE 19.2.4 (Omnibus package) with the bundled PostgreSQL and Redis, Gitaly on a separate host, and the Ultimate feature set licensed, including GitLab Duo Chat which is enabled for all engineering groups. The repository commits API is used by the release tooling and by Argo CD. CI/CD configuration is parsed from .gitlab-ci.yml files in every project; projects may define their own regular expressions in rules and artifact settings. The instance is upgraded on the vendor's monthly cadence by Platform Engineering, usually within three weeks of a release.

JFrog Artifactory 7.111.12

Artifactory 7.111.12 Self-Hosted runs as an active-passive pair with a shared filestore. Anonymous access is disabled: every download requires an identity or access token, and build pipelines use short-lived scoped tokens issued at job start. The default configuration from the vendor installer is in use apart from the authentication settings, the SSO integration with Keycloak and the repository layout. The pair is reachable from the engineering VPN, the platform cluster and the production clusters' image pull path.

Jenkins 2.568.1

Jenkins LTS 2.568.1 remains in service for 23 legacy jobs of the warehouse-management system that depend on Groovy pipeline libraries not yet ported to GitLab CI. Eleven agents connect inbound over the JNLP Remoting port from pods in the platform cluster; the agent connection secret is stored in the cluster. Users with Agent/Connect permission are the agent service accounts and the three legacy service accounts noted in F-2026-021. The controller is upgraded on the LTS line about once a quarter.

Jenkins Script Security Plugin 1402.v94c9ce464861

The Script Security Plugin sandboxes the Groovy used by the legacy pipeline jobs. Engineers with Job/Configure permission on the legacy folder can edit pipeline scripts, which the sandbox is expected to contain. Plugin updates are applied together with the quarterly controller upgrade.

Argo CD 3.3.12

Argo CD 3.3.12 runs in the platform cluster and holds cluster credentials for staging and production. Applications are defined per team with PostDelete hooks used by two teams for database migrations. The repo-server is reachable from all namespaces in the platform cluster because network policies have not yet been applied to the argocd namespace (finding F-2026-023). SSO is through Keycloak with role mapping by group.

Harbor 2.15.1

Harbor 2.15.1 stores the images built by the pipelines, signs them with the platform's cosign key and scans them with the bundled Trivy scanner. Project administrators are the team leads of each engineering team; a second scanner registration (the commercial scanner evaluated in Q1) is still configured with its API credentials. Production clusters are configured to pull only from this registry.

Kubernetes 1.33.2

A nine-node cluster deployed with kubeadm, containerd runtime, Cilium networking. Network policies are enforced in the runner namespaces but not yet in the argocd namespace. The API server is reachable from the Platform Engineering workstations and the bastion only.

Docker Engine 28.1.1

Two worker nodes run Docker Engine for pipeline jobs that need a Docker daemon (image builds for the legacy jobs). Rootless mode is not enabled; the daemon socket is exposed only to the runner pods pinned to these nodes.

5. Network exposure

The platform is internal: nothing is reachable from the internet, and the hosts have no direct internet route. Reachability from the engineering VPN and the office networks is broad by design (every engineer uses GitLab), so the practical attack surface is any engineer's workstation or VPN credential, plus the pipeline content that engineers control.

Build pipelines execute code from merge requests, including from contractors' forks after a maintainer approves the pipeline, so the runner namespaces are treated as hostile and isolated with network policies. The Jenkins controller and Artifactory are reachable from the runner namespaces because jobs need them.

5.1 Exposed endpoints

Port / protocol	Service	Reachable from	Authentication
443/tcp	GitLab web and API	Engineering VPN and office networks	Keycloak staff realm (MFA); project and personal access tokens
22/tcp	GitLab SSH (git)	Engineering VPN and office networks	SSH keys
8443/tcp	Jenkins web and API	Engineering VPN	Keycloak staff realm; three local service accounts
50000/tcp	Jenkins JNLP (Remoting) agent port	Platform cluster runner namespaces	Agent secret
8082/tcp	Artifactory web	Engineering VPN	Keycloak SSO; scoped access tokens; anonymous access disabled
443/tcp	Harbor registry and UI	Engineering VPN	Keycloak OIDC; robot accounts
443/tcp	Argo CD UI and API	Engineering VPN	Keycloak OIDC with group roles
6443/tcp	Kubernetes API (platform cluster)	Platform Engineering workstations and bastion	OIDC + RBAC

6. Security controls

Control	Status	Last verified	Notes
No internet ingress; egress only through the proxy allowlist	In place	2026-05-15	Remote repositories in Artifactory are the only path to public registries.
SSO with MFA for staff	Partial	2026-05-15	Three Jenkins local service accounts without MFA (F-2026-021).
Short-lived scoped tokens for pipeline access to Artifactory	In place	2026-05-15	Issued per job; 2-hour lifetime.
Runner namespace isolation (network policies)	In place	2026-05-10	Not applied to the argocd namespace (F-2026-023).
Image signing and admission policy on production clusters	In place	2026-05-10	cosign signatures verified at admission.
Weekly authenticated vulnerability scan	In place	2026-05-18	All hosts; container images scanned in Harbor on push.
Centralised logging to the SIEM	In place	2026-05-15	GitLab audit events
Backups of repositories and artifacts	In place	2026-04-28	See Appendix B.

7. Open findings

Id	Severity	Finding	Owner	Due
F-2026-021	High	Three Jenkins service accounts use local passwords without MFA and hold Agent/Connect and Job/Configure permissions.	Platform Engineering	2026-08-31
F-2026-022	Medium	GitLab runner registration tokens have not been rotated for more than twelve months.	Platform Engineering	2026-09-30
F-2026-023	Medium	The argocd namespace has no network policy; the repo-server is reachable from every namespace in the platform cluster.	Platform Engineering	2026-09-30
F-2026-024	Low	A second scanner registration in Harbor with live API credentials remains from the Q1 evaluation.	Platform Engineering	2026-10-31

8. Ownership and contacts

Role	Name	Contact
Owner Team lead	Aisha Okonkwo	aisha.okonkwo@larkspur-logistics.example
Technical lead (GitLab and Artifactory)	Daniel Kowalczyk	daniel.kowalczyk@larkspur-logistics.example
Technical lead (Kubernetes and Argo CD)	Sofia Marchetti	sofia.marchetti@larkspur-logistics.example
Legacy Jenkins maintainer	Henrik Dahl	henrik.dahl@larkspur-logistics.example
SecOps liaison	Priya Nandakumar	secops@larkspur-logistics.example

Platform Engineering owns every component of the platform. The legacy Jenkins jobs are owned by the Warehouse Systems team, which is responsible for migrating them to GitLab CI by the end of 2026; until then Platform Engineering operates the controller.

9. Assessment history

Date	Version	Summary
2025-02-10	1.0	Initial assessment of the consolidated platform.

Date	Version	Summary
2025-11-18	1.2	Harbor and image signing added; Jenkins scope reduced to legacy jobs.
2026-05-22	1.4	Annual review; four findings open; Argo CD network policy gap recorded.

Appendix A. Service and port matrix

Host	Port	Service	Listens on	Purpose
gitlab-01	443	GitLab (nginx bundled)	198.51.100.60	Web
gitlab-01	22	GitLab Shell	198.51.100.60	Git over SSH
gitlab-gitaly-01	8075	Gitaly	198.51.100.65	Repository storage RPC
jenkins-01	8443	Jenkins	198.51.100.70	Controller UI and API
jenkins-01	50000	Jenkins Remoting	198.51.100.70	Inbound agents
artifactory-01/02	8082	Artifactory	198.51.100.75-76	Repositories and API
harbor-01	443	Harbor	198.51.100.85	Registry and UI
k8s-plat-cp-01..03	6443	kube-apiserver	198.51.100.80-82	Cluster API

Appendix B. Backup, recovery and change management

Backups: GitLab takes a nightly backup (repositories, database, uploads) to the object store with 30-day retention; Gitaly storage is snapshotted every six hours. Artifactory's filestore is replicated to the secondary node and backed up weekly; the configuration is exported nightly. Harbor's database and storage are backed up nightly. Restores of GitLab and Artifactory were exercised on 2026-04-28 (recovery time six hours).

Change management: component upgrades are scheduled through the weekly CAB and executed outside business hours in Europe. GitLab follows the vendor's monthly release within three weeks; Artifactory and Harbor are upgraded quarterly; Jenkins LTS quarterly. Emergency security upgrades use the emergency change procedure and are announced to engineering on the status channel.

Appendix C. Change log

Date	Change	Approved by
2026-02-20	Argo CD upgraded to 3.3.12.	CAB
2026-03-27	Artifactory upgraded to 7.111.12 on both nodes.	CAB
2026-04-11	Jenkins LTS upgraded to 2.568.1; Script Security Plugin updated to 1402.v94c9ce464861.	CAB
2026-04-25	Harbor upgraded to 2.15.1.	CAB
2026-05-09	GitLab EE upgraded to 19.2.4; Duo Chat enabled for engineering groups.	CAB